

Documentación Técnica: Orquestador Central

`auditoria.py`

Suite de Auditoría de Seguridad Informática

21 de junio de 2026

1. Introducción

El script `auditoria.py` es el orquestador principal y punto de entrada por línea de comandos (CLI) de la Suite de Auditoría de Seguridad. Su propósito principal es coordinar, validar y registrar de manera segura la ejecución de diversos módulos independientes de reconocimiento, escaneo, enumeración y ataque, desarrollados por diferentes grupos de trabajo.

2. Validación Pre-Importación y Estructura

Para asegurar que los archivos mantengan los nombres de archivo acordados en las fases del proyecto (la denominada “*Regla de Oro*”), el script realiza una comprobación estricta de la presencia de cada módulo en los directorios correspondientes antes de proceder con sus import:

- **Fase I (Reconocimiento y Descubrimiento):** `dns_recon.py`, `osint.py`, `discovery.py`, y `scanning.py`. Ubicados en `modulos/Fase_I/`.
- **Fase II (Enumeración y Ataques):** `banner_grabber.py`, `smb_enumerator.py`, `bruteforce_ftp.py`, y `bruteforce_web.py`. Ubicados en `modulos/Fase_II/`.
- **Fase III (Aplicaciones Web y Reportes):** `web_crawler.py`, `vuln_xss_lfi.py`, y `vuln_sql_i.py` en `modulos/`, así como `reportes.py` en `modulos/Fase_III/`.

Si algún archivo no es localizado, el script termina la ejecución inmediatamente emitiendo un mensaje de error crítico explicativo.

3. Funciones Adaptadoras (Wrappers)

Dado que las implementaciones de la Fase II y la Fase III utilizan un paradigma orientado a objetos, el orquestador implementa funciones adaptadoras para instanciar las clases y configurar sus diccionarios o parámetros por defecto:

- `wrapper_banner_grabbing(target)`: Instancia la clase `BannerGrabber`.
- `wrapper_smb_enumeration(target)`: Instancia la clase `SMBEnumerator`.

- `wrapper_ftp_bruteforce(target)`: Instancia la clase `FTPBruteForcer` y carga credenciales de prueba por defecto.
- `wrapper_web_bruteforce(target)`: Adapta el objetivo a una URL (por defecto `login.php`), define los campos de formulario y carga diccionarios.
- `wrapper_web_crawler(target)`: Instancia la clase `WebCrawler`.
- `wrapper_vuln_xss_lfi(target)`: Instancia la clase `XSS_LFI_Scanner`.
- `wrapper_vuln_sql_i(target)`: Instancia la clase `SQLi_Scanner`.

4. Validación de Contratos y Manejo de Errores

El script realiza un control de calidad estricto sobre las respuestas de los módulos:

4.1. Esquema de Validación (JSON Schema)

El orquestador verifica que cada diccionario devuelto cumpla con el esquema oficial definido en `docs/schema_resultados.json` a través de la función `validar_resultado(resultado)`. Si la librería `jjsonschema` está instalada, valida campos obligatorios tales como:

- `modulo`, `grupo`, `estudiante`, `target`, `timestamp`.
- `status` (cuyo valor debe ser `"success"` o `"error"`).
- `data` (resultados del módulo).
- `error_message` (mensaje de error si el estado falló).

4.2. Ejecución Segura

La función `ejecutar_modulo(func, *args, **kwargs)` encapsula la llamada al módulo con bloques `try-except`. Si el módulo falla o lanza una excepción no controlada, esta es capturada y el orquestador genera un diccionario de error estructurado que contiene el *traceback* detallado en el campo `error_message`, evitando que la suite completa falle y permitiendo que se registre la incidencia.

5. Persistencia de Resultados

La función `guardar_historial(resultados)` lee el archivo `historial_auditoria.json` (si existe y es válido), concatena los nuevos resultados y los persiste nuevamente en formato JSON estructurado.

6. Uso y Parámetros del CLI

El orquestador utiliza la biblioteca `argparse` para definir las siguientes banderas agrupadas por categoría:

Categoría	Bandera	Descripción
General	target	Dominio o dirección IP objetivo.
Reconocimiento (DNS)	-dns-all -dns-a -dns-mxns -dns-txtsoa	Ejecuta todas las consultas DNS/WHOIS. Consulta registros A/AAAA (G1-E1). Consulta registros MX/NS (G1-E2). Consulta registros TXT/SOA (G1-E3).
OSINT	-whois -dorks	Consulta WHOIS del objetivo (G2-E1). Subdominios y búsquedas mediante dorks (G2-E2/E3).
Descubrimiento / Escaneo	-scan PUERTOS -ping-sweep -tcp-syn -tcp-ack	Escaneo TCP/UDP de puertos (G4). Descubrimiento ICMP (G3-E1). Descubrimiento TCP SYN (G3-E2). Descubrimiento TCP ACK (G3-E3).
Fase II (Ataques)	-banner -smb -brute-ftp -brute-web	Captura de banners en puertos comunes (G1). Enumeración de sesiones nulas SMB (G2). Fuerza bruta a servicios FTP (G3). Fuerza bruta a formularios Web (G4).
Fase III (Web y Reporte)	-crawl -sqli -xss-lfi -report	Rastreo y mapeo de sitios Web (G1). Escaneo de inyección SQL (G3). Escaneo de vulnerabilidades XSS/LFI (G4). Generación de reporte final HTML/CSV/TXT a partir del historial (G2).

Cuadro 1: Opciones de Línea de Comandos de `auditoria.py`

7. Compromiso Ético

Al iniciar cualquier ejecución, el orquestador imprime una advertencia clara sobre el uso estrictamente académico y ético de la herramienta, haciendo hincapié en que ejecutar ataques sin consentimiento explícito constituye una actividad ilícita.